

# Secure your MERN app.

The essentials from our Common app session.

## 01 Ownership

Check on the server who may read or edit each record.

## 02 Editable fields

Accept intended fields; keep roles and ownership server-controlled.

## 03 Safe comments

Render text safely. Sanitize rich HTML when you deliberately support it.

## 04 Cookie writes

Apply CSRF protection and an appropriate origin policy.

## 05 Verified login

Verify JWT signatures and expiry; design logout deliberately.

## 06 Login abuse

Limit repeated attempts and keep credentials out of logs.

## 07 Safe queries

Validate input types. Build MongoDB queries on the server.

## 08 Public responses

Return only the fields the reader is allowed to see.

Also discussed: server-calculated prices, atomic stock updates and safe link previews.

# Meet Common.

Clone the source. Explore the repairs. Apply them to your own project.

**Open the GitHub codebase >**

**Tejas021/common-mern-security**

## React + Express + Node.js + MongoDB

A local student reference with the demonstrated repairs enabled: profiles, posts, comments, admin permissions and the fictional shop.

### 1. Clone and install

Use the GitHub README for the clone command. Requires Node  $\geq 22.12$  and npm.

```
npm ci
npm run build
```

### 2. Start MongoDB

In the same folder, run this and leave the terminal open:

```
npm run mongo
```

### 3. Open a second terminal

In the app folder:

```
npm run seed -- --confirm-reset
npm start
```

**Open:** `http://127.0.0.1:4200`

**Login:** `hermione@common.demo`

**Password:** `CommonDemo!2026`

First setup needs internet. Seeding replaces local practice data. This is a local teaching reference; review its README before deployment.

# Start for free.

Choose a path. You do not need to complete every course.

## QUICK INTRODUCTION

### Hacksplaining

Free for personal use. Short interactive lessons on common web-security risks and their prevention.

[Open course >](#)

## CLOSEST FIT FOR SECURE CODING

### Snyk Learn

Free JavaScript security and OWASP API Security lessons. Practise the controls in your own Express/React project.

[Open course >](#)

## STRUCTURED FOLLOW-UP / LFD121

### OpenSSF: Developing Secure Software

Free course and completion certificate after passing the exam. Plan about 20 hours; some coding knowledge is expected.

[Open course >](#)

## GO DEEPER

### PortSwigger Web Security Academy

Free web-security learning and labs. Connect each topic to the controls that prevent it.

[Open course >](#)

## STRENGTHEN YOUR MERN FOUNDATIONS

### Full Stack Open

Free React/Node/MongoDB development and testing. A substantial coding course, with prerequisites.

[Open course >](#)

Need broader basics? [Cisco](#) or [Harvard CS50](#) are free options.

# Optional paid picks.

Udemy courses. Check previews and the checkout price first.

SOERIN BIPAT / VOCABULARY

## OWASP Top 10 (No Code)

A short conceptual refresher: about 1h 38m. Useful for the names and ideas; not a MERN code-along.

[Open course >](#)

DEREK FISHER / SECURITY DESIGN

## Application Security: The Complete Guide

About 12h 33m. OWASP, threat modelling and security throughout development. Broader than MERN.

[Open course >](#)

JONAS SCHMEDTMANN / BACKEND COMPANION

## Node.js, Express, MongoDB & More

About 42 hours. Backend projects with auth and security sections. Check older examples against current documentation.

[Open course >](#)

Prices vary. Suggested personal cap: INR 800 for one optional course during a sale; this is a budget, not a quoted price. The free path is enough to begin.

**Your next step: review ONE route.**

Who is calling? What may they access? Which fields may they change? What data may they see?

Test success and denial. Keep protected data unchanged on denial. Read [Express security guidance](#) and the [OWASP cheat sheets](#).